Where does our sign-in stand?

Business: Example Electrical Ltd Date: 23 October 2026

Sources checked: 19 October 2026; corrected points 23 October 2026

At least one of the three first steps is open.

Step 1 open, step 2 open, step 3 open. The three steps are what the authorities cited below recommend first and what security questionnaires from customers and insurers ask about.

What you told us

MFA on email	No
MFA on admin and remote access	No
Second factor	None, or we do not know
Password manager	No
Shared accounts	No
Password rules	No rules
Leavers	No
Recovery	No

Where you stand

Step 1: a second factor on every account that matters
Email or admin accounts without a second factor, or nobody knows.
OPEN

Step 2: one long password per account, kept by a password manager
Shared logins, or neither a password manager nor a length rule.
OPEN

Step 3: one account per person, leavers off the same day, recovery tested
Accounts of leavers are not disabled the same day, or nobody knows.
OPEN

Findings

FACT The US standards body NIST published revision 4 of its Digital Identity Guidelines in July 2025; it supersedes revision 3. For passwords it requires: a minimum of 15 characters where the password is the only factor, and at least 8 characters where it is part of multi-factor authentication; no other composition rules such as required mixtures of character types; no periodic change, but a forced change where there is evidence of compromise; a check of every new password against a blocklist of commonly used, expected or compromised passwords; and that password managers and autofill are allowed; it recommends allowing paste. Failed attempts are rate-limited.

→ NIST SP 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management, July 2025, sections 3.1.1.1, 3.1.1.2 and 3.2.2 · pages.nist.gov/800-63-4/sp800-63b.html · retrieved 2026-10-19, section 3.1.1.2 · retrieved 2026-10-23

FACT The German Federal Office for Information Security (BSI) writes that the advice to change passwords regularly is outdated: regular changes without a reason lead to weaker passwords, and employers should neither demand nor technically enforce them. A password is changed when there is a suspicion that it has leaked. Instead the BSI recommends strong passwords, a second factor or passkeys, and a password manager. Its IT-Grundschutz module ORP.4 requires that every user identifier can be attributed to one person, that unneeded identifiers and permissions are removed on personnel changes, that a password is never used for more than one system, that systems ask for a change only with a valid reason and avoid purely time-driven changes, and that a written copy exists only for an emergency and is kept securely.

→ BSI, press releases of 31 January 2025 ("Passwortwechseln war gestern") and 30 January 2026 ("Der Ändere-dein-Passwort-Tag braucht ein Update") · bsi.bund.de · retrieved 2026-10-19; BSI, IT-Grundschutz-Kompendium, module ORP.4 Identity and Access Management, requirements A1, A2, A8, A22, A23, and module ORP.2 Personnel, A2, edition 2023 · bsi.bund.de · retrieved 2026-10-19

FACT The US cybersecurity agency CISA ranks the forms of multi-factor authentication from strongest to weakest: phishing-resistant methods (FIDO/WebAuthn security keys and passkeys, PKI); app-based one-time codes, push notifications with number matching and hardware tokens; push notifications without number matching; and codes by SMS or voice call, which are vulnerable to phishing, SS7 and SIM-swap attacks and should be used only as a last resort. For small and medium businesses that cannot implement phishing-resistant MFA at once, CISA names app- or token-based codes and push with number matching as the best options. In June 2022 CISA's director said that multi-factor authentication can make you 99 % less likely to get hacked; a Microsoft study of real attack data found that it reduces the risk of compromise by 99.2 %.

→ CISA, fact sheet "Implementing Phishing-Resistant MFA", October 2022, pp. 1 to 3 · cisa.gov · retrieved 2026-10-19; CISA, news release of 6 June 2022 and blog of 5 May 2022 · cisa.gov · retrieved 2026-10-19; Microsoft Digital Defense Report 2023 and Microsoft Research, "How effective is multifactor authentication at deterring cyberattacks?", May 2023 · microsoft.com · retrieved 2026-10-19

FACT ENISA's guide for small and medium businesses encourages a passphrase of at least three random common words; for ordinary passwords it still suggests mixed character types, which NIST no longer requires. It asks never to reuse or share passwords, to enable multi-factor authentication, to use a dedicated password manager, to enforce strong passwords and where possible MFA for remote access, and to revoke an employee's access to business systems when they leave.

→ ENISA, "Cybersecurity guide for SMEs: 12 steps to securing your business", June 2021, steps 4 and 5 and the remote-access step (step 4 · retrieved 2026-10-23); ENISA, "Cybersecurity for SMEs: Challenges and Recommendations", June 2021, pp. 36 to 37 · enisa.europa.eu · retrieved 2026-10-19

FACT The Austrian portal onlinesicherheit.gv.at recommends at least twelve characters for normal accounts and longer passwords or additional authentication for accounts with special rights, at least twenty characters for wireless networks and encrypted files, a change whenever there is a suspicion that a password became known to others, and password managers; it describes security keys as an effective measure against phishing and man-in-the-middle attacks. A WKO page of 2016 still online recommends eight characters and a change every three to six months; the WKO's own news of January 2026 says the opposite: length matters, at least twelve characters, change only on a concrete suspicion.

→ onlinesicherheit.gv.at (Federal Chancellery and A-SIT), "Passwort-Auswahl" (updated 9 December 2025), "Passwort-Umgang" (6 February 2020), news on FIDO security keys (19 September 2023) · retrieved 2026-10-19; WKO, "Passwörter: Die Schlüssel zu Computer und Internet", status 6 June 2016, and WKO Kärnten, "Passwort vergessen, Konto gesperrt", updated 28 January 2026 · wko.at · retrieved 2026-10-19

■ FACT For businesses covered by NIS 2, the measures must include basic cyber hygiene and cybersecurity training, access control policies, and the use of multi-factor or continuous authentication where appropriate. Germany and Austria wrote this wording into their laws.

→ Directive (EU) 2022/2555, Art. 21(2), points (g), (i) and (j) · EUR-Lex · retrieved 2026-10-19; BSI-Gesetz, § 30(2), no. 10 · gesetze-im-internet.de · retrieved 2026-10-19; NISG 2026, § 32(4), lit. j · ris.bka.gv.at · retrieved 2026-10-19

◆ INTERPRETATION Multi-factor authentication without a tested recovery locks the business out when a phone is lost or the administrator is unavailable. Recovery codes printed and kept offline, a second administrator, and a dated test of the procedure are part of the same step.

◌ GAP No source read gives a legal minimum for the sign-in security of a business outside NIS 2. The standards above are what the authorities recommend and what security questionnaires ask; a contract with a customer or an insurer may demand more.

◐ UNCERTAIN The BSI consumer pages carry no date; the IT-Grundschutz module read is from edition 2023, the latest full edition; the BSI is introducing IT-Grundschutz++ (to be checked at bsi.bund.de). CISA does not name the research behind its 99 % figure; the figure is reported as its statement, not as a measurement of this memo.

What to do next

- [ ] This week: switch on multi-factor authentication for every email account and every admin, remote, banking, shop and cloud account; use an authenticator app or a security key, SMS only as a last resort.
- [ ] Roll out a password manager for everyone; one long password per account, 15 characters or more where there is no second factor; at least 12 elsewhere (onlinesicherheit.gv.at; NIST sets 8 as the floor with MFA); no forced rotation; change on suspicion; no shared logins.
- [ ] Write a list of all accounts and who holds them; an offboarding checklist that disables accounts the same day; recovery codes printed and kept offline; a second administrator; a dated test of the recovery.
- [ ] Write the three steps down as a one-page sign-in rule and keep a dated note of what was switched on when; this is the evidence a questionnaire asks for.

The Security Evidence Toolkit turns these steps and the other measures a customer or insurer asks about into a self-declaration, an action plan and an emergency card: scutoria.com/toolkits/security-evidence.

Sources

1. NIST Special Publication 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management, July 2025, published 1 August 2025, supersedes revision 3: sections 3.1.1.1, 3.1.1.2, 3.2.2, 4.2. pages.nist.gov/800-63-4/sp800-63b.html and doi.org/10.6028/NIST.SP.800-63B-4 · retrieved 2026-10-19.
2. BSI, press release of 31 January 2025, "Passwortwechseln war gestern", and of 30 January 2026, "Der Ändere-dein-Passwort-Tag braucht ein Update"; consumer pages "Sichere Passwörter erstellen", "Umgang mit

Passwörtern" and "Zwei-Faktor-Authentisierung" (undated). bsi.bund.de · retrieved 2026-10-19.

3. BSI, IT-Grundschutz-Kompendium, edition 2023: ORP.4 Identitäts- und Berechtigungsmanagement (A1, A2, A8, A9, A22, A23); ORP.2 Personal (A2). bsi.bund.de · retrieved 2026-10-19. Edition 2023 is the latest full edition; the BSI is introducing IT-Grundschutz++ (to be checked at bsi.bund.de; heise, "IT-Grundschutz++", and SVA, flyer 2026 · retrieved 2026-10-23).
4. CISA, fact sheet "Implementing Phishing-Resistant MFA", October 2022; news release of 6 June 2022, "More Than a Password" campaign; blog "Walk this way to enable MFA", 5 May 2022. cisa.gov · retrieved 2026-10-19.
5. Microsoft, Digital Defense Report 2023 (reporting period July 2022 to June 2023); Microsoft Research, "How effective is multifactor authentication at deterring cyberattacks?", May 2023; Microsoft Security Blog, 20 August 2019. microsoft.com · retrieved 2026-10-19.
6. ENISA, "Cybersecurity guide for SMEs: 12 steps to securing your business", June 2021, and "Cybersecurity for SMEs: Challenges and Recommendations", June 2021. enisa.europa.eu · retrieved 2026-10-19.
7. Austria: onlinesicherheit.gv.at, "Passwort-Auswahl" (9 December 2025), "Passwort-Umgang" (6 February 2020), "Mehrfaktor-Authentifizierung" (6 October 2020), news on FIDO security keys (19 September 2023); WKO, "Mehr Sicherheit durch Mehr-Faktor-Authentifizierung" (12 September 2022), "Passwörter: Die Schlüssel zu Computer und Internet" (6 June 2016), WKO Kärnten news of 28 January 2026. retrieved 2026-10-19.
8. Directive (EU) 2022/2555 (NIS 2), Art. 21(2). eur-lex.europa.eu · retrieved 2026-10-19. Germany: BSI-Gesetz of 2 December 2025, § 30(2). gesetze-im-internet.de · retrieved 2026-10-19. Austria: NISG 2026, BGBl. I No. 94/2025, § 32(4), in force since 1 October 2026. ris.bka.gv.at · retrieved 2026-10-19.

This memo is information based on the sources listed, generated on 23 October 2026 from the answers above. It is not legal advice and decides nothing on behalf of your business. Every statement carries its marker, every source its retrieval date; check the sources again before you rely on a date.